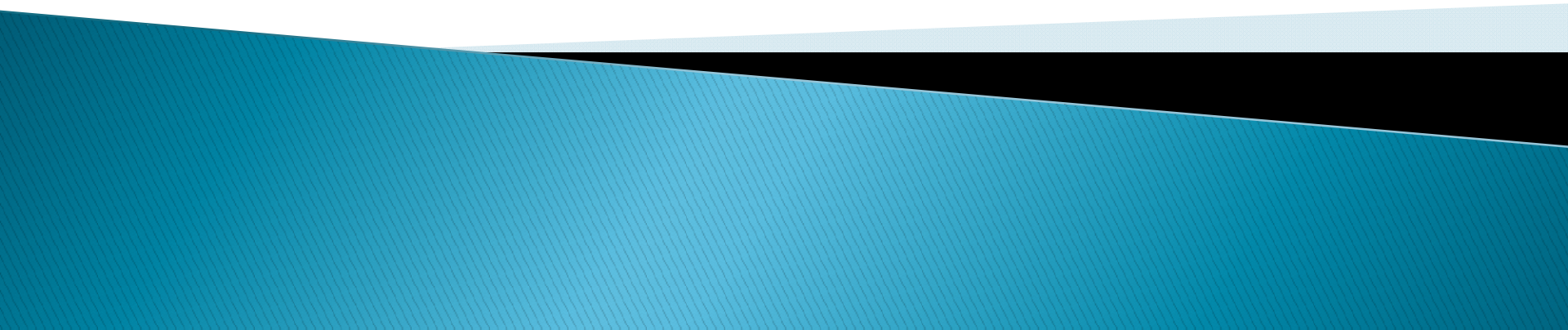


Computer Security and Cyber Law

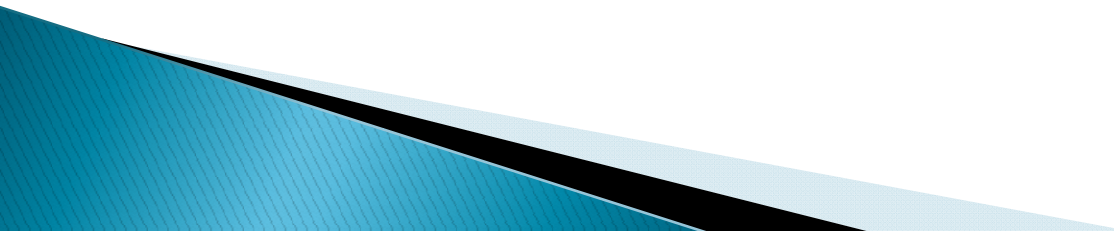
Unit 5

Design Principles and Common Security Related Programming Problems

Lecturer: Binod Chandra Shrestha



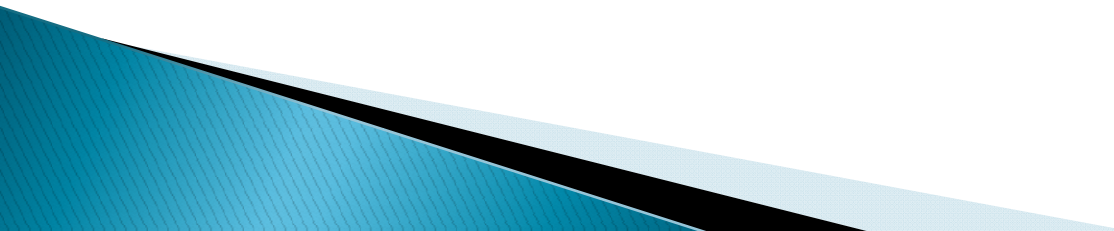
Design Principles

- Principle Of Least Privilege
 - This principle restricts how privileges are granted
 - This principle state that “a subject should be given only those privilege that it need in order to complete its task
 - Principle of Fail-Safe Defaults
 - Restricts how privileges are initialized when a subject or object is created.
 - States that, unless a subject is given explicit access to an object, it should be denied access to that object.
 - This principle requires that the default access to an object is none
- 

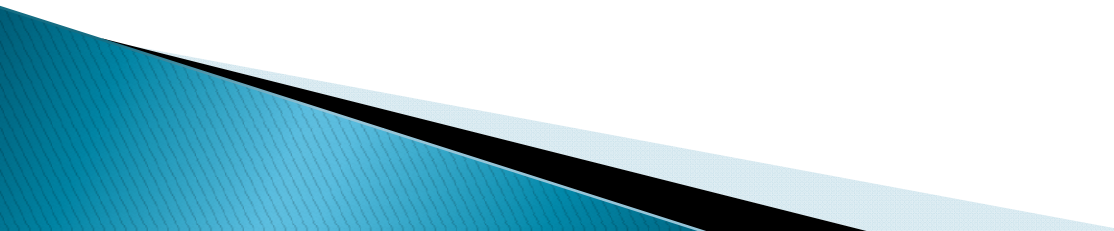
Design Principles

- Principle of Economy of Mechanism
 - Simplifies the design and implementation of security mechanisms.
 - State that security mechanisms should be as simple as possible
- Principle of complete mediation
 - Requires that all accesses to be checked to ensure that they are allowed.
 - All access level should be checked not only the first one in order to grant permission

Design Principles

- Principle of Open Design
 - This principle suggests that complexity does not add security.
 - State that the security of a mechanism should not depend on the secrecy of its design or implementation to ensure security.
 - Principle of Separation of Privilege
 - This principle is restrictive because it limits access to system entities.
 - States that a system should not grant permission based on a single condition.
- 

Design Principles

- Principle of Least Common Mechanism
 - This principle is restrictive because it limits sharing
 - States that the mechanisms used to access resources should not be shared.
 - Principle of Psychological Acceptability
 - This principle recognizes the human elements in computer security
 - States that security mechanism should not make the resources more difficult to access than if there is no security mechanisms were not present.
- 

Common Security Related Programming Problems

- A) Improper Choice of Initial Protection Domain
 - Flaws arise from incorrect setting of permissions or privileges
 - 1) Process Privileges
 - The principle of least privilege dictates that no process have more privileges than it needs to complete its task, but the process must have enough privileges to complete its task successfully
 - Implementation Rule 1
 - Structure the process so that all sections requiring extra privileges are modules. The modules should be as small as possible and should perform only those tasks that require those privileges
 - Management Rule 1
 - Check that the process privileges are set properly.

Common Security Related Programming Problems

- 2) Access Control File Permissions.
 - Biba's model emphasize that the integrity of the process relies on both the integrity of the program and integrity of the access control file.
 - Verifying the integrity of the access control file is critical, because that file controls the access to role accounts.
 - Management Rule 2
 - The program that is executed to create the process, and all associated control files, must be protected from unauthorized use and modification. Any such modification must be detected.
 - Implementation Rule 2
 - Ensure that any assumptions in the program are validated. If it is not possible, document them for the installer and maintainers, so they know the assumptions that attackers will try to invalidate.

Common Security Related Programming Problems

– 3) Memory Protection

- Consider sharing memory. If two subjects can alter the contents of memory, then one could change data on which the second relies. This sharing poses a security problem because the modifying process can alter variables that control the action of the other process. Each process should have a protected, unshared memory space.
- Implementation Rule 3
 - Ensure that the program does not share objects in memory with any other program, and that other programs cannot access the memory of a privileged.
- Management Rule 3
 - Configure memory to enforce the principle of least privilege.
 - If a section of memory is not contain executable instructions, turn execute permission off for that section of memory. If the contents of a section of memory are not be altered make that section read-only.

Common Security Related Programming Problems

- 4) Trust in the System
 - The program relies on the system authentication mechanisms to authenticate the user and on the user information database to map user and roles into their corresponding UIDs.
 - It also relies on the inability of ordinary users to alter the system clock.
 - Implementation Rule 4
 - Identify all systems components on which the program depends. Check for errors whenever possible, and identify those components for which error checking will not work.

Common Security Related Programming Problems

- ▶ B) Improper Isolation of Implementation Detail
 - This problem arises when an abstraction is improperly mapped into an implementation detail
 - Implementation Rule 5
 - The error status of every function must be checked. Do not try to recover unless the cause of the error, and its effects, do not affect any security consideration. The program should restore the state of the system to the state before the process began, and then terminate.

Common Security Related Programming Problems

- 1) Resource Exhaustion and User Identifiers
 - The designers and implementers decided to have the program fail if, for any reason, the query failed. This application of the principle of fail-safe defaults ensured that in case of error, the users would not get access to the role account.
 - 2) Validating the Access Control Entries
 - The expression of the access control information is therefore the result of mapping an abstraction to an implementation.
 - The question is whether or not the given access control information correctly implements the policy.
 - 3) Restricting the Protection Domain of the Role Process
- 

Common Security Related Programming Problems

- C) Improper Changes
 - This category describes data and instructions that change over time. The danger is that the changed values may be inconsistent with the previous values.
 - 1) Memory
 - Any process that can access shared memory can manipulate data in the memory. Unless all processes that can access the shared memory implement a concurrent protocol for managing changes one process can change data on which a second process relies
 - This could cause the second process to violate the security policy.
- 

Common Security Related Programming Problems

- Implementation Rule 6
 - If a process interacts with other processes, the interactions should be synchronized. In particular, all possible sequences of interactions must be known and for all such interactions, the process must enforce the required security policy.
- Implementation Rule 7
 - Asynchronous exception handlers should not alter any variables excepts those that are local to the exception handling module.
 - Exception handler should block all the exception
- Implementation Rule 8
 - Data that the process trusts and the data that it receives from un-trusted sources should be kept in separate areas of memory

Common Security Related Programming Problems

▶ D) Improper Naming

- It refers to an ambiguity in identifying an object
- If two different objects have the same name.
- The programmer intends the name to refer to one of the objects, but an attacker manipulates the environment and the process so that the name refers to a different object.
- Management Rule 5
 - Unique objects require unique names. Interchangeable objects may share a name.
- Implementation Rule 9
 - The process must ensure that the context in which an object is named identifies the correct object.

Common Security Related Programming Problems

- ▶ E) Improper Deallocation or Deletion
 - Failing to delete sensitive information raises the possibility of another process seeing that data at a later time.
 - Cryptographic keywords, passwords and other authentication information should be discarded once they have been used.
 - As a consequence of not deleting sensitive information is that dumps of memory, which may occur if the program receives an exception or crashes for some other reason.
 - Implementation Rule 10
 - When the process finishes using a sensitive object, the object should be erased, the de-allocated or deleted. Any resources not needed should also be released.

Common Security Related Programming Problems

▶ F) Improper Validation

- This problem arises when data is not checked for consistency and correctness.
- The process can check correctness only by looking for error codes or by looking for patently incorrect values.
- 1) Bounds Checking
 - Errors of validation often occur when data is supposed to lie within bounds.
 - Implementation Rule 11
 - Ensure that all array references access existing elements of the array. If a function that manipulates arrays cannot ensure that only valid elements are referenced, do not use that function. Find one that does, write a new version, or create a wrapper.

Common Security Related Programming Problems

– 2) Type Checking

- Failure to check types in another common validation problem.
- Implementation Rule 12
 - Check the type of function and parameters.
- Management Rule 6
 - When compiling programs, ensure that the compiler flags report inconsistencies in types. Investigate all such warnings and either fix the problem or document the warning and why it is spurious.

– 3) Error Checking

- Third common problem involving improper validation is failure to check return values of function.

Common Security Related Programming Problems

- Implementation Rule 13
 - Check all function and procedure executions for errors.
- 4) Checking for valid, not invalid data.
 - This principle requires that valid values be known and that all other values be rejected. Unfortunately, programmers often check for invalid data and assume that the rest is valid.
 - Implementation Rule 14
 - Check that a variable's values are valid.
 - Management Rule 7
 - If a trade-off between security and other factors results in a mechanism or procedure that can weaken security, document the reasons for the decision, the possible effects, and the situations in which the compromise method should be used.

Common Security Related Programming Problems

– 5) Checking Input

- All the data from the un-trusted sources must be checked
- Implementation Rule 15
 - Check all user input for both form and content. In particular, check integer for values that are too big or too small, and check character data for length and valid characters. (check that a variable's values are valid.)

◦ 6) Designing for validation

- Sometimes data cannot be validated completely.
- Implementation Rule 16
 - Create data structure and function in such a way that they can be validated.

Common Security Related Programming Problems

▶ G) Improper Indivisibility

- It arises when an operation is considered as one unit in the abstract but is implemented as two unit.
- Implementation Rule 17
 - If two operations must be performed sequentially without an intervening operation, use a mechanism to ensure that the two cannot be divided.

▶ H) Improper Sequencing

- Means that operations are performed in an incorrect order.
- Implementation Rule 18
 - Describe the legal sequences of operations on a resource or object. Check that all possible sequence of the programs involved match one legal sequences

Common Security Related Programming Problems

- ▶ J) Improper choice of operand or operation
 - Preventing errors of choosing the wrong operand or operation requires that the algorithms be thought through carefully.
 - Management Rule 8
 - Use software engineering and assurance techniques to ensure that operations and operands are appropriate.

Assignment 5

- ▶ Describe all Design Principles with examples.
- ▶ Explain all Common Security Related Programming Problems with examples.